

03_PLAYBOOKS_PROCEDURES_REX

Playbooks, procedures et REX incidents - SOC Daylight

Objectif

Ce document formalise la reponse operationnelle du SOC Cyber Trust pour Daylight. Il complete le demontreteur Wazuh avec des procedures exploitables par un analyste, un superviseur et un administrateur.

Matrice de qualification

Niveau	Critere	Exemple	Action
---	---	---	---
Critique	Donnee patient exposee, privilege eleve, compromission probable	Acces massif dossier patient, modification groupe admin	Escalade immediate, confinement, notification responsable.
Haute	Tentatives d'intrusion repetees ou attaque confirmee	Brute force SSH, brute force applicatif	Qualification prioritaire, blocage source si possible.
Moyenne	Comportement suspect sans impact confirme	USB inhabituel, anomalie endpoint	Verification, enrichissement, surveillance.
Basse	Evenement informatif ou hygiene	Controle SCA, evenement systeme	Suivi, tendance, durcissement.

Procedure generale de triage

1. Identifier la source : endpoint, serveur, application, messagerie ou reseau.
2. Lire la regle Wazuh, le niveau, l'horodatage et l'actif concerne.
3. Verifier si l'alerte est isolee ou correlee a d'autres signaux.
4. Enrichir avec le contexte : utilisateur, site Daylight, type de donnees, criticite metier.
5. Classer l'incident : faux positif, evenement a surveiller, incident confirme.
6. Appliquer le playbook adapte.
7. Documenter les preuves et actions.
8. Cloturer avec un REX si l'incident est significatif.

Playbook PB-001 - Brute force SSH

Champ	Detail
---	---
Regle	`5712`
Source	`serveur-01`, `/var/log/auth.log`
Criticite	Haute
Objectif	Detecter et contenir des tentatives d'authentification repetees.

Etapes

1. Verifier le nombre de tentatives et l'adresse source.
2. Confirmer que l'utilisateur cible n'est pas un compte de service legitime.
3. Chercher une connexion reussie apres les echecs.
4. Si attaque confirmee, bloquer l'adresse source sur firewall ou regle locale.
5. Forcer la rotation du mot de passe si un compte valide est vise.

6. Conserver les logs auth.log et l'alerte Wazuh.
7. Escalader a l'administrateur si une connexion reussie suit les echecs.

Criteres de cloture

- Source bloquee ou jugee non dangereuse.
- Aucun succes d'authentification suspect.
- Preuves archivees.

Playbook PB-002 - Acces anormal dossier patient

```
| Champ | Detail |
|---|---|
| Regle | `100120` |
| Source | Application Daylight |
| Criticite | Critique |
| Objectif | Proteger les donnees patients et detecter les acces hors profil. |
```

Etapes

1. Identifier l'utilisateur, le site et le dossier patient concerne.
2. Verifier le profil metier de l'utilisateur.
3. Comparer l'accès avec les horaires et habitudes connues.
4. Chercher d'autres dossiers consultes dans la meme fenetre de temps.
5. Si suspicion confirmee, suspendre temporairement le compte ou reduire les droits.
6. Prevenir le responsable Cyber Trust et le referent Daylight.
7. Preparer les elements pour analyse RGPD si exposition de donnees personnelles.
8. Documenter la chronologie et les decisions.

Criteres de cloture

- Justification metier validee ou incident confirme.
- Compte securise.
- Liste des dossiers touches documentee.
- REX produit si incident confirme.

Playbook PB-003 - Brute force applicatif Daylight

```
| Champ | Detail |
|---|---|
| Regle | `100110` |
| Source | Application metier |
| Criticite | Haute |
| Objectif | Detecter une attaque contre l'authentification applicative. |
```

Etapes

1. Identifier le compte vise et l'adresse source.
2. Verifier le volume d'echecs et la periode.
3. Chercher une connexion reussie apres la sequence.
4. Declencher une reinitialisation de mot de passe si necessaire.
5. Proposer blocage IP ou limitation de debit.

6. Documenter les preuves dans la fiche incident.

Playbook PB-004 - Modification groupe privilegie

```
| Champ | Detail |
|---|---|
| Regle | `100130` |
| Source | Daylight / annuaire simule |
| Criticite | Critique |
| Objectif | Detecter une elevation de privileges non autorisee. |
```

Etapes

1. Identifier le compte ajoute ou modifie.
2. Identifier l'auteur de la modification.
3. Verifier s'il existe une demande de changement valide.
4. Si non valide, retirer le privilege.
5. Rechercher les actions realisees par le compte depuis la modification.
6. Escalader a l'administrateur et au chef de projet SOC.
7. Produire un REX obligatoire.

Playbook PB-005 - Usage USB suspect

```
| Champ | Detail |
|---|---|
| Regle | `100140` ou evenement endpoint |
| Source | Poste de travail |
| Criticite | Moyenne a haute |
| Objectif | Controler l'usage de supports amovibles sur postes Daylight. |
```

Etapes

1. Identifier le poste et l'utilisateur.
2. Verifier si l'usage USB est autorise dans le centre.
3. Rechercher une copie de fichiers sensibles.
4. Isoler le poste si un transfert suspect est confirme.
5. Sensibiliser l'utilisateur et proposer une regle de blocage si recurrent.

Playbook PB-006 - Phishing ou piece jointe suspecte

```
| Champ | Detail |
|---|---|
| Source | Messagerie Outlook, Zimbra ou webmail |
| Criticite | Moyenne a critique |
| Objectif | Reagir a un signalement ou une detection de phishing. |
```

Etapes

1. Collecter l'email original et les en-tetes.
2. Identifier les destinataires Daylight.
3. Verifier liens, pieces jointes et domaine expéditeur.
4. Rechercher les clics ou ouvertures.
5. Purger le message si la messagerie le permet.

6. Reinitialiser les mots de passe des utilisateurs touches si vol d'identifiants.

7. Ajouter les indicateurs de compromission aux listes de surveillance.

Procédure de gestion d'incident

```
| Etape | Responsable | Sortie attendue |
|---|---|---|
| Detection | Wazuh / analyste | Alerte qualifiée. |
| Qualification | Kilyan / analyste SOC | Severite, impact, priorite. |
| Confinement | Mahamadou / admin | Compte suspendu, IP bloquee, poste isole. |
| Remediation | Yvan / Youssef / Mahamadou | Correction technique ou regle ajustee. |
| Communication | Kilyan | Message client et statut. |
| REX | Mahamadou | Fiche post-incident et axes d'amelioration. |
```

Modele de fiche incident

```

ID incident :
Date / heure :
Source :
Regle Wazuh :
Actif concerne :
Utilisateur :
Site Daylight :
Severite :
Resume :
Preuves :
Actions immediates :
Decision :
Impact :
Cause probable :
Actions correctives :
Responsable :
Statut :

```

REX incident simule 1 - Brute force SSH

```
| Champ | Detail |
|---|---|
| Incident | Tentatives SSH repetees sur `serveur-01` |
| Detection | Regle Wazuh `5712` |
| Impact | Pas de compromission confirmee dans le scenario de demo |
| Cause | Simulation d'attaque par script |
| Action | Verification des echecs, controle absence de succes, documentation |
| Amelioration | Ajouter blocage automatique apres seuil et alerte superviseur |
```

REX incident simule 2 - Acces dossier patient

```
| Champ | Detail |
|---|---|
| Incident | Acces anormal a un dossier patient Daylight |
| Detection | Regle `100120` |
| Impact | Risque de consultation non autorisee de donnee sensible |
| Action | Qualification critique, verification utilisateur, escalade |
| Amelioration | Ajouter un tableau de bord par site et un seuil par profil metier |
```

REX incident simule 3 - Modification groupe privilege

Champ	Detail
---	---
Incident	Modification d'un groupe privilege
Detection	Regle `100130`
Impact	Risque d'elevation de privileges
Action	Verification demande de changement, retrait privilege si non valide
Amelioration	Coupler la detection a un workflow de validation IAM

Indicateurs de pilotage

KPI	Definition	Usage
---	---	---
Nombre d'alertes critiques	Alertes de niveau critique sur la periode	Priorisation client.
Temps de qualification	Delai entre detection et classification	Performance SOC.
Taux de faux positifs	Alertes fermees sans incident	Amelioration des regles.
Sources actives	Nombre de sources qui remontent des logs	Qualite de couverture.
Incidents avec REX	Part des incidents significatifs documentes	Amelioration continue.